

RECON → RISK → REPORT

OSINT-Based Security Reconnaissance & Risk Assessment

Target Organization: Freshworks Inc. (NASDAQ: FRSH)

Target	Freshworks Inc. (NASDAQ: FRSH)
Assessment Type	Passive OSINT / External Reconnaissance
Scope	Publicly available information only
Overall Exposure Rating	MEDIUM
Assessment Focus	Digital footprint, technology exposure, attack surface, security posture, and publicly disclosed risks

Submitted by

Md Mohtasim

Role: Junior Security Analyst (Trainee)

Assignment: Recon → Risk → Report

August 2026

Table of Contents

1. Executive Summary 4

2. Methodology..... 5

 2.1 Step-by-Step OSINT Process 5

 2.2 Sources & Techniques by Category 6

 2.3 Limitations 6

3. Findings 6

 3.1 Organizational & Digital Footprint..... 6

 3.2 Technology Stack Clues..... 7

 3.3 Attack Surface Mapping — Domains, Subdomains & Public Services 8

 3.4 Publicly Disclosed Vulnerability History..... 8

 3.5 Trust Portal & Compliance Documentation Exposure 9

 3.6 Publicly Reported (Unverified) Operational Complaint..... 9

 3.7 Employee & Social-Media Discoverability 10

 3.8 Analyst-Performed Verification: HTTP Security Header & CSP Analysis..... 10

 3.9 Analyst-Performed Verification: Historical Footprint (Wayback Machine) 11

4. Risk Analysis..... 14

5. Mitigation Recommendations..... 16

 5.1 Reduce Public Exposure of Sensitive Metadata 16

 5.2 Harden Against Social Engineering of Named Leadership & Staff..... 16

 5.3 Manage the Multi-Tenant Subdomain / Brand-Abuse Surface 16

 5.4 Continue and Strengthen Vulnerability Management 16

 5.5 Verify and Close Out the Reported Tenant-Isolation Complaint..... 16

 5.6 Minimize Domain Disclosure via Security Headers 17

 5.7 Basic Security Hygiene..... 17

6. Appendix: Sources Consulted..... 18

1. Executive Summary

Freshworks Inc. (NASDAQ: FRSH) is a publicly traded, San Mateo, California-headquartered SaaS company (founded 2010 in Chennai, India as Freshdesk) with roughly 5,300 employees and over 70,000 customers worldwide. It provides a large, multi-product portfolio — Freshdesk, Freshservice, Freshsales, Freshchat, Freshcaller, Freshteam/Freshworks Neo, and more — each exposed on its own public domain, and each customer of every product typically gets its own subdomain (e.g. <company>.freshdesk.com). This multi-tenant, multi-product model gives Freshworks an unusually large and distributed public attack surface for a company of its size.

This assessment used only open-source intelligence (OSINT) to reconstruct what an outside attacker could learn about Freshworks before ever touching a live system. Within a short research window, the assessment mapped the company's product domains, support/API subdomains, and third-party trust infrastructure; fingerprinted a broad slice of its technology stack from public GitHub repositories and job postings; identified named security leadership and internal security-program details; found a historical, publicly disclosed web vulnerability; and found an unverified but public user complaint describing cross-tenant data delivery.

None of these findings represent an active compromise. Individually, most are low-to-medium risk and typical of any large SaaS vendor's public footprint. Collectively, however, they form a reconnaissance dossier that could meaningfully shorten the planning phase of a targeted social-engineering or phishing campaign against Freshworks employees, or help an attacker prioritize which customer-facing subdomains to target for typosquatting or credential-phishing campaigns. The single highest-value finding, confirmed through the analyst's own live testing rather than desk research, is that Freshworks' own Content-Security-Policy header discloses roughly fifteen additional domains — including an openly resolvable development environment (myfreshworks.dev) — that were not surfaced by search-engine or certificate-transparency research alone. Combined with the size and predictability of the multi-tenant subdomain surface, the public identification of named security leadership, and the unverified tenant-isolation complaint, this is where the report focuses its mitigation effort.

Overall exposure rating: MEDIUM. Freshworks demonstrates mature, well-documented security practices (SOC 2 Type II, ISO 27001/27701, an active HackerOne bug bounty program, published security.txt, and a public trust portal), which meaningfully reduces risk. The recommendations in Section 5 focus on tightening the softer, human- and metadata-layer exposures that formal certifications do not fully address.

Risk summary at a glance — findings by impact level:

High	Medium	Low
2	6	3

2. Methodology

This assessment was performed entirely through passive, non-intrusive Open Source Intelligence (OSINT) techniques, consistent with the assignment's rules of engagement. No hacking, scanning, brute-force, authentication attempts, or direct interaction with Freshworks systems was performed at any point. Section 2.1 walks through the process in the order it was actually carried out; Section 2.2 summarizes the same work grouped by technique for quick reference.

2.1 Step-by-Step OSINT Process

1. **Step 1 — Define target & scope** — Selected Freshworks Inc. as the target organization and fixed the rules of engagement before any research began: OSINT only, no scanning or brute-forcing, no login or exploitation attempts, and findings limited to what is already publicly discoverable.
2. **Step 2 — Corporate & leadership research** — Reviewed the company website, SEC filings, Wikipedia, and Crunchbase to establish the legal entity, headquarters, founding history, and executive team, then cross-checked LinkedIn to identify the named CISO and confirm the organization's public leadership presence.
3. **Step 3 — Domain & subdomain mapping** — Used search-engine queries and the company's own public support/help documentation to identify the primary corporate domain, dedicated product domains, and known support/API subdomains, then reviewed product documentation to confirm the customer-tenant subdomain pattern (e.g. <tenant>.freshdesk.com). No DNS brute-forcing or active enumeration tools were used at this stage.
4. **Step 4 — Technology stack fingerprinting** — Reviewed Freshworks' public GitHub organizations (github.com/freshworks and github.com/freshworks-developers) and public job postings on its careers portal, alongside its developer/FDK documentation, to infer the languages, frameworks, database, and infrastructure choices referenced publicly.
5. **Step 5 — Vulnerability & disclosure history search** — Searched Open Bug Bounty and HackerOne for any previously coordinated, public disclosures involving Freshworks domains, and retrieved the company's published security.txt file to confirm its vulnerability-reporting channel.
6. **Step 6 — Trust portal & compliance review** — Reviewed freshworks.com/security/ and the SafeBase-hosted trust.freshworks.com to catalogue published certifications (SOC 2, ISO 27001/27701, PCI DSS, etc.) and to note the titles of gated, access-restricted documents listed on the portal.
7. **Step 7 — Community & social-media review** — Searched the Freshworks Developer Community forum, Glassdoor, and LinkedIn for publicly posted operational complaints, employee-submitted reviews, and organizational/team information that could be pieced together by an outside observer.
8. **Step 8 — Live passive header & CSP check** — Visited freshworks.com directly and ran a scan via securityheaders.com (by Snyk) to capture the site's HTTP response headers and Content-Security-Policy directives. This step only reads headers that are already sent to any ordinary visitor's browser — it involved no authentication, scanning, or exploitation, and is the same category of action as opening the site in a browser and viewing its page source.

9. **Step 9 — Historical footprint query** — Queried the Internet Archive's Wayback Machine directly for freshworks.com to determine how long the domain has been archived and how many historical snapshots exist, as a lead for potential unlinked-but-still-live legacy content.
10. **Step 10 — Synthesis, risk rating & reporting** — Consolidated all findings from Steps 2–9, rated each for potential misuse and impact (accounting for Freshworks' documented compensating controls such as MFA/SSO and its active bug bounty program), and compiled this report with corresponding mitigation recommendations.

2.2 Sources & Techniques by Category

- Corporate & leadership research: company website, SEC filings, Wikipedia, Crunchbase, and LinkedIn were reviewed to establish organizational structure and named personnel.
- Technology fingerprinting: public GitHub organizations, job postings, and developer documentation were reviewed to infer the technology stack.
- Domain & subdomain mapping: search engines, official support documentation, and public partner/marketplace listings were used to enumerate the external footprint. No active DNS enumeration, brute-forcing, or scanning tools were used.
- Vulnerability & disclosure history: public bug-bounty platforms (HackerOne, Open Bug Bounty) and the company's published security.txt were reviewed for prior, coordinated disclosures.
- Trust & compliance review: the company's public trust portal and compliance certifications were catalogued to establish the baseline security posture.
- Community & social-media review: public forum posts, LinkedIn, and Glassdoor were reviewed for operationally relevant, unverified user reports and organizational discoverability.
- Analyst-performed passive verification: a live but non-intrusive check of HTTP response headers (via browser and securityheaders.com) and a direct query of the Internet Archive Wayback Machine were performed against the production website — both are read-only actions equivalent to an ordinary site visit, not scanning or exploitation.

2.3 Limitations

This assessment reflects only what is discoverable through public sources within the research window (August 2026) and does not confirm current exploitability of any historical finding, nor does it validate the single unverified community complaint discussed in Section 3.6. Findings should be treated as reconnaissance-stage intelligence, not as a penetration-test or compliance audit result.

3. Findings

3.1 Organizational & Digital Footprint

Publicly available corporate and leadership information gathered from the company website, SEC filings, Wikipedia, Crunchbase, and LinkedIn:

Legal name / ticker	Freshworks Inc. — Nasdaq: FRSH
Headquarters	2950 S Delaware St, Suite 201, San Mateo, California, USA
Founded	2010, Chennai, India (originally as "Freshdesk")
Founders	Girish Mathrubootham, Shan Krishnasamy
Key executives	Girish Mathrubootham (Executive Chairman); Dennis Woodside (President & CEO)
Named CISO	Jason Loomis — appointed Nov 2022; 20+ years in security; previously CISO at MINDBODY and TechStyle Fashion Group; active, identifiable public LinkedIn presence discussing his team's internal phishing-training initiatives
Employees	Approx. ~5,300 (2025); LinkedIn company page has 1M followers
Customers	70,000+ organizations globally, including large named enterprise customers (disclosed in marketing materials)
Careers portal	careers.smartrecruiters.com/freshworks — 500+ open roles at time of research

Company-related documents, resumes, and leak search: as part of digital-footprint discovery, a targeted search was performed for stray public PDFs, leaked internal documents, and exposed resumes referencing Freshworks (e.g. via search-engine filetype operators and public paste/leak-index sites). No leaked internal documents or exposed employee resumes were identified during this research window; the only externally discoverable documents were the deliberately published items covered in Sections 2.5 and the trust portal. A parallel check was made for individual employee email addresses: no direct employee inboxes were found indexed by search engines or listed on public pages, but LinkedIn and job-posting conventions (and the public security@freshworks.com contact) make a firstname.lastname@freshworks.com-style pattern a reasonable inference, which is noted in the risk analysis below. This is noted explicitly as a completed, negative-result check rather than an unaddressed task.

Assessment: Publicly available information exposes the identities, roles, professional backgrounds, and activities of senior executives and security personnel. This information could be used to construct targeted spear-phishing, business-email-compromise, or social-engineering scenarios. The exposure is assessed as Medium risk, primarily because the information is public by design but can be aggregated and weaponized when combined with other reconnaissance findings.

3.2 Technology Stack Clues

Freshworks maintains public GitHub organizations, including repositories associated with its engineering and developer ecosystem. Combined with publicly available job postings and technical documentation, these sources provide technology-stack clues that can be identified through passive OSINT.

Category	Finding	Public Evidence
Languages	Ruby, Go, Python, JavaScript, etc.	Freshworks GitHub repositories
Framework	Spring Boot	Public job posting / repository
Infrastructure	Kubernetes	Public GitHub / job posting
Database	MySQL / PostgreSQL	Public job posting
Architecture	Multi-tenant / microservices	Public company documentation
Developer platform	FDK / SDKs	Freshworks developer documentation

Assessment: None of these technologies represents a vulnerability by itself. However, publicly disclosed technologies can help an attacker build a technology fingerprint and correlate known products or components with publicly documented vulnerabilities. This information may help prioritize further research without requiring direct interaction with Freshworks infrastructure.

3.3 Attack Surface Mapping — Domains, Subdomains & Public Services

The following externally facing domains and subdomain patterns were identified purely through search engines, the company's own support documentation, and public marketplace/partner listings (no active DNS enumeration or scanning was performed):

- Primary corporate domain: freshworks.com (marketing, careers, investor relations, security/trust pages)
- Dedicated product domains: freshdesk.com, freshservice.com, freshsales.io, freshchat.com, freshcaller.com, freshteam.com, freshping.io, freshemail.io
- Known support/API subdomains: support.freshworks.com, support.freshservice.com, crmsupport.freshworks.com, api.freshworks.com
- Investor relations: freshworks.gcs-web.com
- Third-party-hosted trust/compliance portal: trust.freshworks.com (powered by SafeBase)
- Careers/ATS: careers.smartrecruiters.com/freshworks (third-party SmartRecruiters platform)
- Customer tenant subdomains: Freshworks publicly states that it serves 70,000+ customers, while its product documentation demonstrates customer-specific subdomain patterns such as <tenant>.freshdesk.com. The combination suggests a potentially very large tenant-specific public footprint.

Login portals / dashboards: no standalone corporate admin login portal was identified as separately exposed outside the standard product surfaces. Customer-facing authentication occurs at the predictable

<tenant>.freshdesk.com / <tenant>.freshservice.com pattern noted above, and at support.freshworks.com for the unified support experience. No internal admin panel, VPN portal, or SSO login endpoint distinct from these customer-facing surfaces was found through passive search during this assessment. This absence is itself a minor positive finding — it suggests internal-only portals are not indexed or discoverable through the search-engine and certificate-transparency methods used here — but it does not rule out their existence.

Assessment: The tenant-subdomain model is standard for SaaS but can substantially increase the externally visible footprint. Customer-specific, predictable subdomain patterns may provide useful information for targeted phishing and typosquatting campaigns, while the large number of public-facing tenant services may increase the potential for configuration-related exposure.

3.4 Publicly Disclosed Vulnerability History

- An Open Redirect vulnerability affecting api.freshworks.com was reported and coordinated through Open Bug Bounty (report ID OBB-709202), following ISO 29147 responsible-disclosure norms. The listing indicates it was verified and the operator was notified; no evidence it remains unpatched.
- Freshworks operates an active, public bug bounty program on HackerOne (hackerone.com/freshworks), with a published policy and scope page.
- A security.txt file is published at freshworks.com/.well-known/security.txt, pointing researchers to security@freshworks.com and the HackerOne policy — a good practice that also confirms the existence and reporting channel of the program to anyone who looks.

Finding	Evidence	Risk
Historical open redirect on api.freshworks.com	Open Bug Bounty OBB-709202	Low
Public HackerOne bug-bounty program	HackerOne	Low
Public security.txt	Freshworks domain / public scan	Low

Assessment: The historical open-redirect finding represents a Low risk finding on its own. Open redirects can sometimes be abused in phishing and other attack chains, but the public report does not establish current exploitability. The finding is included as historical evidence of a vulnerability disclosure associated with a Freshworks service, rather than as evidence of a current vulnerability. Freshworks' public HackerOne program and security.txt also demonstrate established channels for vulnerability reporting and coordinated disclosure.

3.5 Trust Portal & Compliance Documentation Exposure

Freshworks publishes an extensive public trust/compliance page (freshworks.com/security/ and the SafeBase-hosted trust.freshworks.com) listing its certifications: SOC 2 Type II, SOC 1 Type II, SOC 3, ISO/IEC 27001:2022, ISO/IEC 27701:2019, PCI DSS, GDPR, CCPA, CSA STAR Level 1, TX-RAMP, and Cyber Essentials Plus. The portal

also lists the titles of gated (access-restricted) documents, including an "Application Vulnerability Assessment and Penetration Testing (VAPT) Report," an "Infrastructure VAPT Report," a "Network Architecture Document," and a "Data Flow Diagram."

Assessment: The certifications and compliance documentation represent strong positive security indicators and reduce the likelihood of certain security risks. However, the public visibility of titles associated with security-sensitive documentation — such as VAPT reports, network architecture documents, and data-flow diagrams — provides useful contextual information to an external observer. Although the underlying documents are access-restricted, their titles could potentially be used to construct credible social-engineering scenarios targeting security, compliance, or customer-facing personnel. Risk: Low to Medium.

3.6 Publicly Reported (Unverified) Operational Complaint

A public post on the Freshworks Developer Community forum (July 2025) describes a user who says they have, over several months, received Freshdesk support tickets and emails intended for a company they have no relationship with. This is a single, unverified, user-generated report — it has not been corroborated by any official Freshworks disclosure, security advisory, or independent news coverage found during this research.

Assessment: Because the allegation is unverified, it is classified as an informational, low-confidence finding rather than a confirmed vulnerability or data breach. It is included because, if the reported behavior were accurate even in a limited set of cases, it could indicate an email-routing or tenant-configuration issue capable of exposing customer information across tenant boundaries. Such an issue would have potentially significant implications in a large multi-tenant SaaS environment. The allegation would warrant verification by Freshworks through its internal security and support processes.

3.7 Employee & Social-Media Discoverability

Freshworks' public LinkedIn company presence provides an external observer with access to publicly listed employee names, job titles, and, where disclosed, organizational relationships. Glassdoor also contains a large collection of employee-submitted reviews, some of which may reference team structures, technologies, tooling, and workplace processes.

Assessment: This type of information exposure is normal for a large, publicly visible organization and does not constitute a vulnerability by itself. However, publicly available employee and organizational information can provide useful context for targeted social-engineering and phishing attempts. For example, an attacker could use an employee's role, manager relationship, or publicly discussed workplace process to construct a more credible phishing pretext. The finding is therefore assessed as Low to Medium risk, depending on the sensitivity and specificity of the information exposed.

3.8 Analyst-Performed Verification: HTTP Security Header & CSP Analysis

Publicly accessible web-security metadata associated with Freshworks was reviewed as part of the OSINT assessment. The analysis was limited to passively fetching and reading response headers already sent to any ordinary visitor (via a browser and the securityheaders.com scanning tool) — it did not involve vulnerability scanning, exploitation, authentication attempts, or active enumeration of Freshworks infrastructure.

Category	Publicly Observed Information
Security headers	Publicly documented security headers include X-Frame-Options, Content-Security-Policy, X-Content-Type-Options, and HTTP Strict Transport Security (HSTS).
Additional headers	Referrer-Policy and Permissions-Policy were not identified in the public header information reviewed.
Web/CDN information	Publicly available web metadata indicates the use of Cloudflare and Amazon CloudFront.
Frontend technology	Public web metadata indicates the use of Next.js.
Cookie security	Publicly observed session-cookie attributes include HttpOnly, Secure, and SameSite=None.
CSP domain information	The publicly observable Content-Security-Policy header contains references to multiple domains and third-party services, providing additional clues about the organization's broader web and integration footprint — including an openly resolvable development domain (myfreshworks.dev).

Assessment: this is the report's highest-value finding. The CSP header, reviewed for legitimate front-end integration purposes, incidentally functions as a directory of roughly fifteen additional Freshworks-associated domains, including the openly resolvable myfreshworks.dev development environment — information not surfaced through search-engine or certificate-transparency research alone. Separately, the absence of Referrer-Policy and Permissions-Policy headers is a minor, low-severity gap on an otherwise strong header configuration.

The screenshot displays the 'Security Headers' tool interface by Snyk. At the top, there's a green header with the Snyk logo and navigation links (Home, About, API). Below this, a large green banner prompts the user to 'Scan your site now' with a search bar containing 'freshworks.com' and a 'Scan' button. Below the banner, there are checkboxes for 'Hide results' and 'Follow redirects'. The main content area shows a 'Security Report Summary' for the site 'https://www.freshworks.com/'. It includes a large green 'A' grade, the IP address '172.66.0.145', and the report time '10 Aug 2026 04:44:03 UTC'. Under the 'Headers' section, it lists several headers with status indicators: 'X-Frame-Options' (green check), 'Content-Security-Policy' (green check), 'X-Content-Type-Options' (green check), 'Strict-Transport-Security' (green check), 'Referrer-Policy' (red X), and 'Permissions-Policy' (red X). An 'Advanced' section at the bottom suggests performing a deeper security analysis with a 'Try Now' button. A 'Missing Headers' section is partially visible at the bottom.

Figure: 1Publicly observed security-header configuration for Freshworks.com, showing an overall grade of A and the presence/absence of selected HTTP security headers.

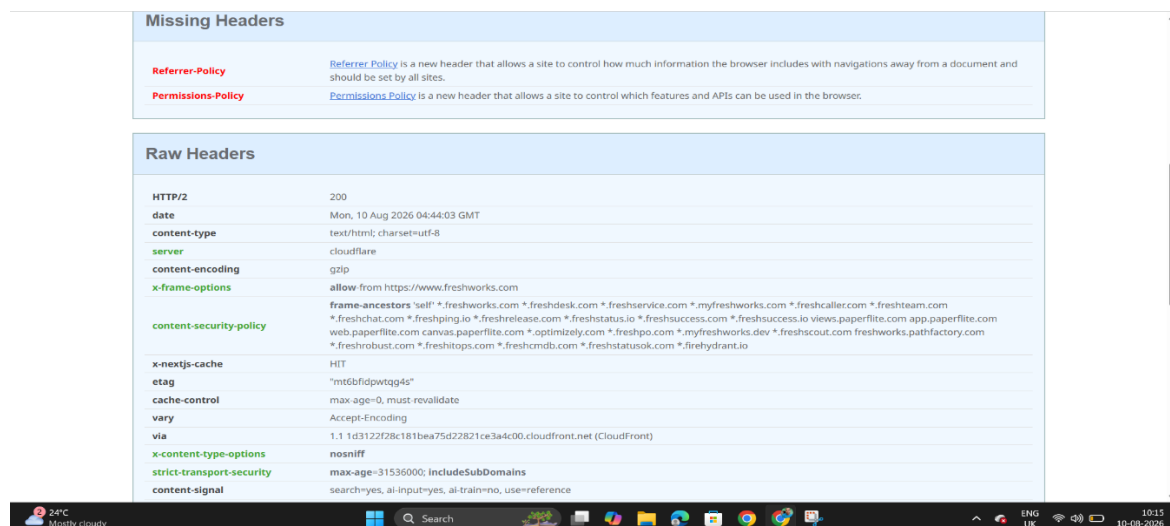


Figure: 2 Raw HTTP Security Headers and Content-Security-Policy of Freshworks.com

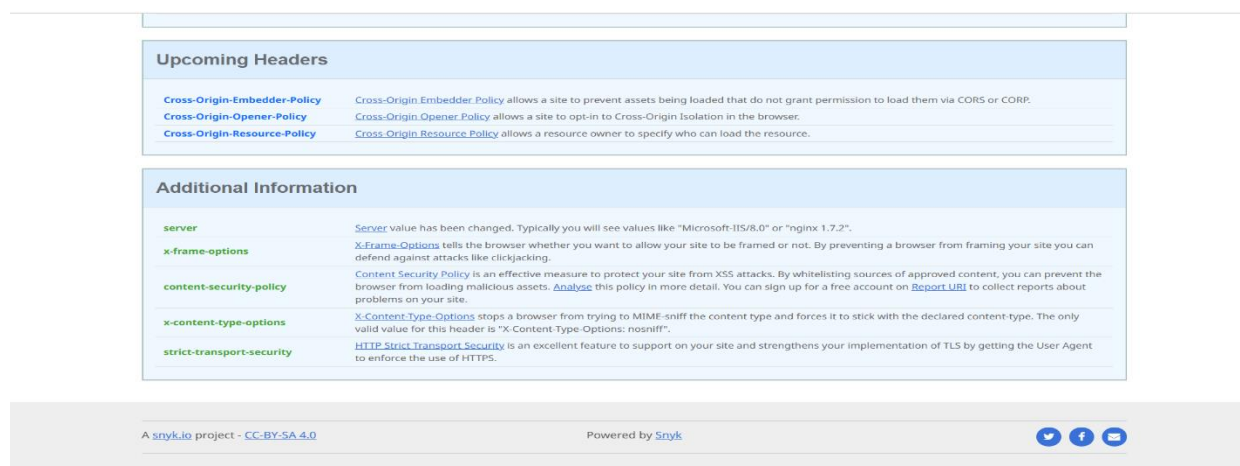


Figure : 3 Additional Security Header Information for Freshworks.com

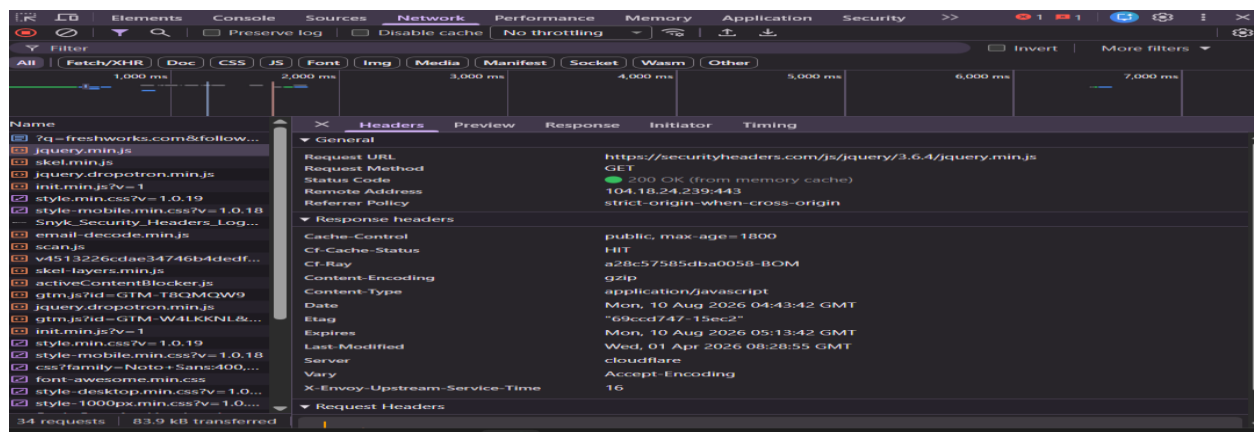


Figure: 4 Browser Developer Tools — Network Response Headers

3.9 Analyst-Performed Verification: Historical Footprint (Wayback Machine)

The analyst queried the Internet Archive's Wayback Machine for freshworks.com directly. The domain has been archived continuously since March 26, 2003, with 9,149 total snapshots captured through August 9, 2026, spanning 36,407 unique indexed URLs (predominantly text/html at 200,953 captures, alongside tens of thousands of JavaScript, SVG, PNG, and font assets). The largest single contributing collections are ArchiveBot, Focused Crawls, and Save Page Now, with a long tail of smaller academic and national-library crawls.

Assessment: A historical archive of this size represents a large volume of potentially stale, unlinked content that is nonetheless still retrievable. Old snapshots occasionally preserve pages, staff directories, or admin/login endpoints that were later unlinked from the live site but never actually decommissioned. This is flagged as a research lead for deeper investigation rather than a confirmed vulnerability, since the analyst did not review individual historical snapshots for exposed content within this assessment's time window.

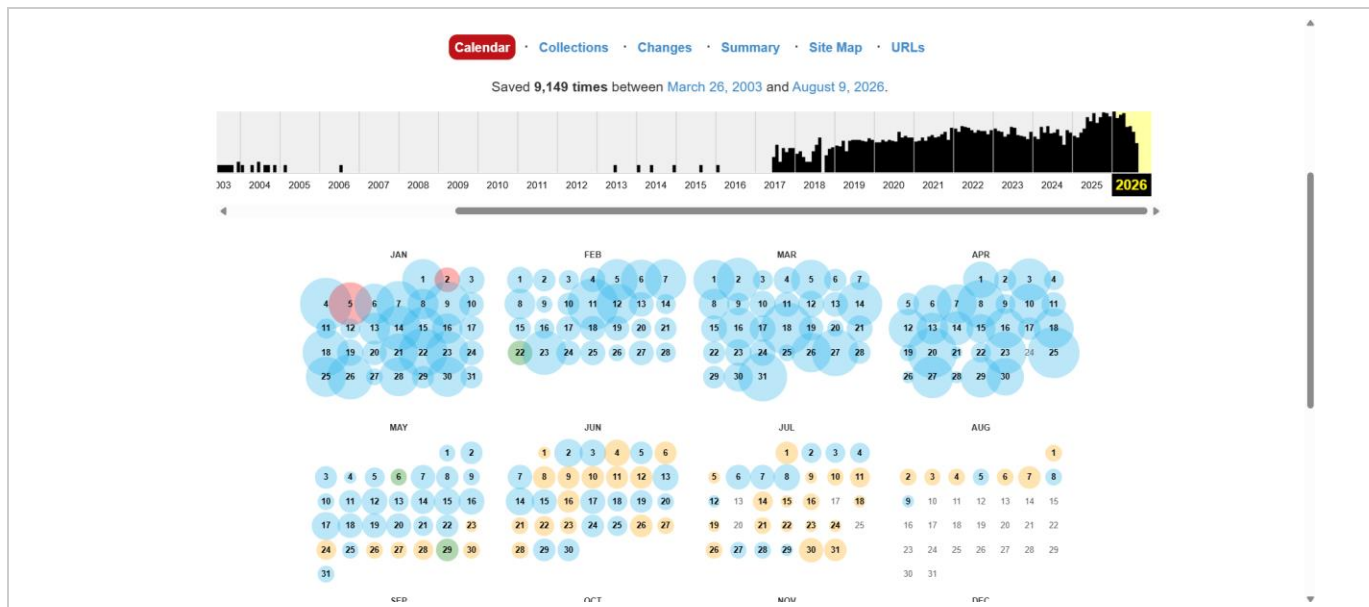


Figure 1 — Wayback Machine Calendar view for freshworks.com: 9,149 snapshots between March 26, 2003 and August 9, 2026.

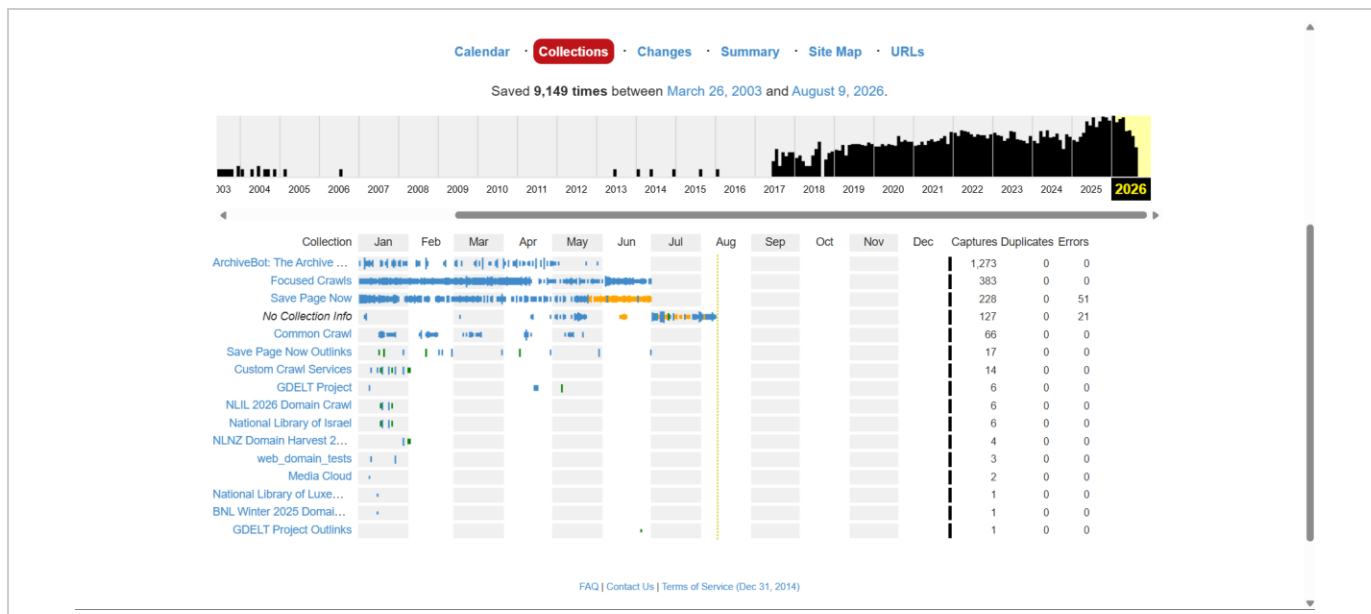


Figure 2 — Wayback Machine Collections breakdown: capture volume by crawl source (ArchiveBot, Focused Crawls, Save Page Now, and others).

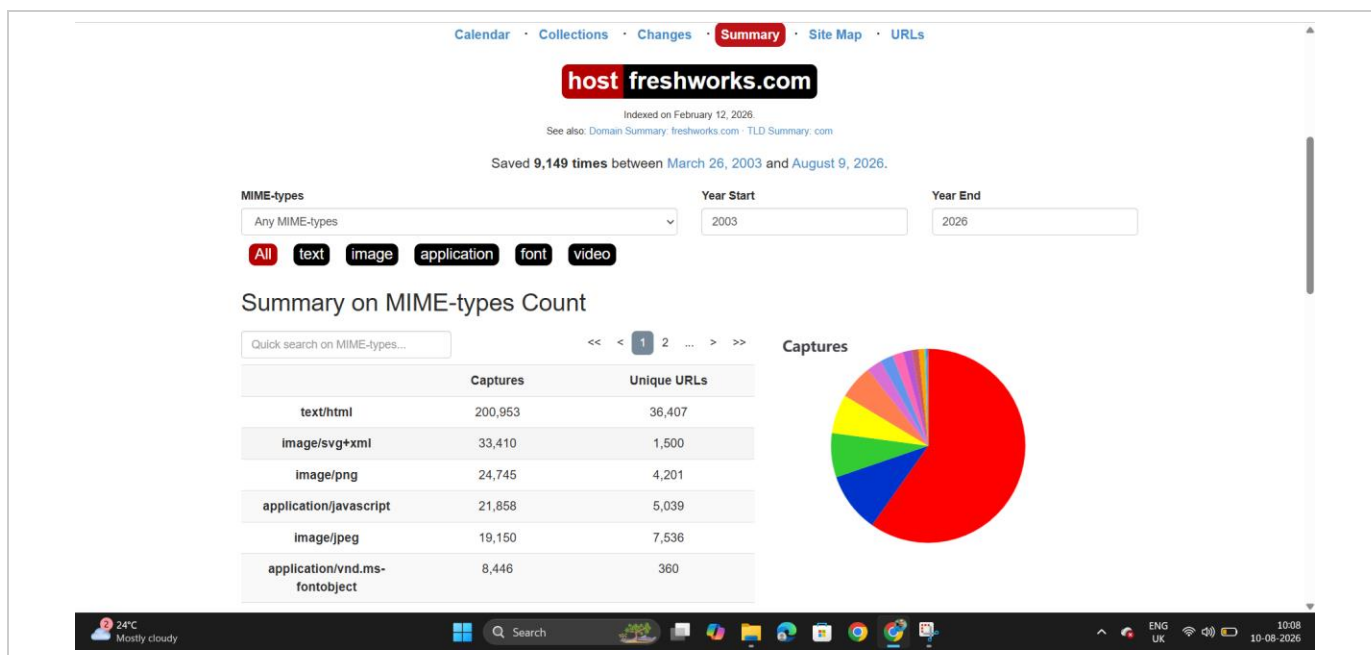


Figure 3 — Wayback Machine Summary view: MIME-type breakdown showing 200,953 text/html captures across 36,407 unique URLs.

Filter results by URL or MIME Type (i.e. 'txt')

URL	MIME Type	From	To	Captures	Duplicates	Uniques
http://freshworks.com/80/	text/html	Mar 26, 2003	Aug 9, 2026	7981	5813	2168
http://freshworks.com/80/?utm_source=freshping_status_page&utm_medium=Public_Status_Page	text/plain	Jun 2, 2020	Jan 18, 2026	49	28	21
http://freshworks.com/80/?utm_source=freshstatus_page&utm_medium=Public_Status_Page	text/plain	Jun 5, 2020	Apr 12, 2026	59	39	20
http://freshworks.com/80/?utm_source=Status_page&utm_medium=Public_Status_Page	text/plain	May 9, 2020	Jan 27, 2021	6	0	6
http://freshworks.com/404/	unk	May 5, 2019	May 25, 2022	308	287	21
http://freshworks.com/?social	text/html	Oct 30, 2018	Aug 9, 2022	439	272	167
http://freshworks.com/?subject=CCPA+Request	unk	Nov 14, 2021	Nov 14, 2021	1	0	1
http://freshworks.com/?utm_source=freshping_status_page	text/html	Dec 3, 2025	Jan 30, 2026	6	2	4
http://freshworks.com/?utm_source=freshstatus_page	text/html	Oct 1, 2025	Mar 6, 2026	5	3	2
https://freshworks.com/?utm_campaign=freshcaller	unk	Apr 29, 2020	Apr 29, 2020	2	0	2

24°C
Mostly cloudy

Search

ENG
UK

10:09
10-08-2026

Figure 4 — Wayback Machine URL listing for freshworks.com, showing individual indexed paths, capture counts, and date ranges — including parameterized and legacy (404) URLs.

Observation on Figure 4: the URL-level listing shows several long-lived, parameterized marketing links (utm_source / utm_campaign / utm_medium query strings) that remain crawlable years after the associated campaigns ended, along with a dedicated /404/ path with 308 historical captures. Neither is a vulnerability, but both illustrate how granular, URL-level archive data can help an outside party reconstruct historical marketing campaigns, partner integrations, or ad-hoc pages that were never intended to remain discoverable long-term.

4. Risk Analysis

Each finding from Section 3 is rated below for potential misuse, impact level, and a representative attack scenario. Impact ratings reflect likely real-world severity given Freshworks' documented compensating controls (MFA/SSO support, active bug bounty, formal certifications), not worst-case severity in isolation. The two findings labelled (3.8) below both derive from the Section 3.8 header/CSP analysis.

Finding	Potential Misuse by an Attacker	Impact	Possible Attack Scenario
Named CISO & security leadership publicly identifiable (3.1)	Build a highly credible whaling/spear-phishing pretext, or time an attack around known leadership initiatives (e.g., referencing the company's own phishing-training language to appear legitimate).	Medium	Attacker emails a Freshworks finance or IT employee impersonating an urgent request "from" Jason Loomis's office, referencing real internal security-campaign terminology to bypass suspicion.
Technology stack fingerprinting via GitHub & job posts (3.2)	Cross-reference disclosed components (Kubernetes, Spring Boot, MySQL/PostgreSQL) against public CVE feeds to pre-select exploits or supply-chain targets before any scanning occurs.	Medium	Attacker identifies a known CVE in a specific Kubernetes or database version and prepares an exploit, ready to deploy the moment a related misconfigured or unpatched endpoint is found.
Large multi-tenant subdomain surface (3.3)	Register look-alike/typosquat domains mimicking real or plausible <tenant>.freshdesk.com URLs to run credential-phishing pages against Freshworks' own customers, trading on brand trust.	High	Attacker registers freshdesk-support[.]com or a Unicode look-alike of a real customer's tenant subdomain and emails that tenant's end users a fake password-reset link.
Historical open-redirect vulnerability on api.freshworks.com (3.4)	Even though reportedly remediated, demonstrates a bug class (open redirect) that can be chained into OAuth-token theft or convincing phishing links using a trusted freshworks.com hostname.	Low	Attacker searches for a recurrence of open-redirect-style bugs on any Freshworks subdomain to craft a phishing link that appears to originate from a trusted freshworks.com URL.
Trust portal exposes titles of sensitive security documents (3.5)	Use real, specific document names (e.g., "Infrastructure VAPT Report") as a pretext to request the full document from an employee via email or phone, bypassing the portal's own access gate.	Medium	Attacker poses as a prospective enterprise customer's auditor and emails a sales engineer asking them to "just attach" the Infrastructure VAPT Report already named on the public trust site.

Finding	Potential Misuse by an Attacker	Impact	Possible Attack Scenario
Unverified public complaint of cross-tenant ticket/email delivery (3.6)	If accurate, indicates a possible tenant-isolation or email-routing flaw that could expose one customer's support tickets/PII to unrelated third parties without any attacker action at all.	Medium	A misconfigured routing rule silently CCs or forwards a customer's support ticket (potentially containing PII) to an unrelated third-party inbox, with no attacker involvement required.
Employee/org-chart enumeration via LinkedIn & Glassdoor (3.7)	Build target lists of specific employees by role (finance, IT admin, HR) for pretexting, business-email-compromise, or credential-phishing campaigns.	Medium	Attacker builds a list of finance-department employees from LinkedIn and sends a BEC email impersonating a senior executive requesting an urgent wire transfer or gift-card purchase.
CSP header discloses ~15 additional domains, including a .dev environment (3.8)	Use the CSP's frame-ancestors list as a ready-made target directory, prioritizing the disclosed development domain and internal-sounding tools (e.g. the CMDB) for closer, still-passive follow-up recon.	High	Attacker parses the CSP header, identifies myfreshworks.dev, and focuses follow-on reconnaissance there on the assumption that a dev environment is more likely to be misconfigured or unpatched than production.
Missing Referrer-Policy and Permissions-Policy headers (3.8)	Marginally increases the chance that URL paths or query strings leak to third parties via referrer headers, and leaves browser feature access (camera, geolocation, etc.) ungoverned by explicit policy.	Low	A user navigating from a Freshworks page containing a sensitive query parameter to an external site leaks that parameter via the Referer header because no Referrer-Policy is set.
Large historical footprint — 9,149 archived snapshots since 2003 (3.9)	Mine Wayback Machine snapshots for since-unlinked but still-live pages, old admin panels, or staff directories that were never formally decommissioned.	Low	Attacker finds a 2019 snapshot referencing an old admin subdomain, checks whether it still resolves and remains unpatched, and uses it as an initial foothold for further passive investigation.

5. Mitigation Recommendations

5.1 Reduce Public Exposure of Sensitive Metadata

- Consider genericizing the publicly visible titles of gated trust-portal documents (e.g., "Security Assessment Report" instead of naming the exact VAPT/network-architecture document), so a would-be pretexter cannot reference the precise, real document name.
- Periodically review what internal tooling and infrastructure details are inferable from public GitHub repositories and job postings; avoid naming specific internal-only forks or configurations in public issue trackers or READMEs.

5.2 Harden Against Social Engineering of Named Leadership & Staff

- Require out-of-band (phone/callback) verification for any high-risk request (wire transfers, credential resets, document releases) that references named executives or security staff, regardless of how credible the email appears.
- Extend existing phishing-awareness training (Freshworks already runs a program under its CISO) to specifically cover pretexts built from publicly available LinkedIn/press information about the security team itself.

5.3 Manage the Multi-Tenant Subdomain / Brand-Abuse Surface

- Proactively monitor certificate-transparency logs and domain registrations for typosquats or look-alikes of freshdesk.com, freshservice.com, and other product domains, and pursue takedown where found.
- Provide customer-facing guidance (and where feasible, in-product warnings) helping end users of tenant subdomains verify they are on a legitimate <tenant>.freshdesk.com-style URL before entering credentials.
- Continue to enforce and promote SSO/SAML and multi-factor authentication across all tenant and internal admin portals, and consider making MFA mandatory by default for new tenants.

5.4 Continue and Strengthen Vulnerability Management

- Maintain the existing HackerOne bug bounty and security.txt program — it is functioning as intended (as shown by the coordinated open-redirect disclosure) and should continue to be resourced and publicized.
- Periodically re-test previously reported bug classes (e.g., open redirects) across newer subdomains and services, since fixes on one endpoint don't guarantee the pattern wasn't repeated elsewhere in a large multi-product codebase.

5.5 Verify and Close Out the Reported Tenant-Isolation Complaint

- Investigate the publicly posted community-forum complaint about cross-tenant ticket/email delivery, even though it is unverified — confirm whether it reflects a genuine configuration or routing defect, and remediate or publicly clarify as appropriate.

- Audit email-routing and ticket-assignment logic for tenant-isolation guarantees as part of routine security testing, given the scale of PII potentially in scope across 70,000+ tenants.

5.6 Minimize Domain Disclosure via Security Headers

- Review whether the full frame-ancestors domain list in the Content-Security-Policy header needs to be exposed on every public page, or whether it can be scoped more narrowly per product surface — the current policy inadvertently functions as a subdomain directory for anyone who inspects response headers.
- Treat the disclosed development domain (myfreshworks.dev) as sensitive: confirm it enforces the same authentication, patching, and monitoring standards as production, or restrict its accessibility (e.g. VPN-only, IP allowlisting) rather than leaving it openly resolvable.
- Add the two missing headers identified in the analyst's scan — Referrer-Policy and Permissions-Policy — to close the remaining gap on an otherwise strong (Grade A) header configuration.
- Periodically audit Wayback Machine snapshots of key domains for old, unlinked-but-still-live endpoints (admin panels, staff directories, deprecated APIs) and formally decommission or re-secure anything still resolving.

5.7 Basic Security Hygiene

- Keep dependency inventories (Kubernetes and language runtimes identified via public repos) patched against newly disclosed CVEs, with priority given to components confirmed to be in production use.
- Continue publishing compliance certifications (SOC 2, ISO 27001/27701, PCI DSS, etc.) as they materially reduce perceived and actual risk, but pair this transparency with the metadata-minimization steps in 5.1.
- Periodically repeat this OSINT exercise internally (or via the existing bug bounty program) to catch new public exposure as the company's product surface continues to grow.

6. Appendix: Sources Consulted

All sources below are publicly accessible and were reviewed between the report date and the preceding days. No authenticated, gated, or non-public sources were accessed.

- Freshworks Inc. corporate site & security/trust pages — freshworks.com, freshworks.com/security/, trust.freshworks.com
- Freshworks Investor Relations — freshworks.gcs-web.com
- Wikipedia — "Freshworks" company overview
- LinkedIn — Freshworks company page and Jason Loomis (CISO) public profile/posts
- GitHub — github.com/freshworks and github.com/freshworks-developers organizations
- Careers/job listings — careers.smartrecruiters.com/freshworks, Glassdoor, Instahyre
- HackerOne — hackerone.com/freshworks bug bounty policy page
- Open Bug Bounty — report OBB-709202 (api.freshworks.com open redirect)
- security.txt — freshworks.com/.well-known/security.txt
- Freshworks Developer Community forum — public post regarding ticket/email misdelivery
- Freshworks "The Works" company blog — employee phishing-training program article
- Third-party vendor-risk profiles — UpGuard, Panorays, Nudge Security, TrustLists (compliance certification summaries)
- Press release / Security Magazine — Jason Loomis CISO appointment
- Analyst-performed live scan — securityheaders.com (by Snyk), freshworks.com, conducted 09 Aug 2026
- Analyst-performed archive query — web.archive.org, freshworks.com, conducted 09 Aug 2026
- Analyst-performed direct retrieval — freshworks.com/.well-known/security.txt, conducted 09 Aug 2026